

RED TEAM LEARNING PATH

MODULE 07

Reconnaissance & OSINT

Omarchy / Arch Linux Edition

AUTHORIZED-LAB RULE

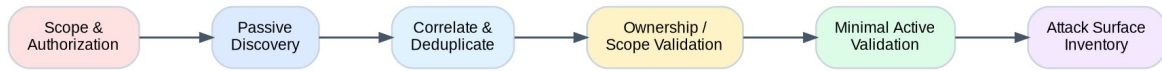
Gunakan teknik aktif hanya pada localhost, lab milik sendiri, atau aset yang secara eksplisit tercantum dalam scope. Data publik yang menemukan hostname baru tidak otomatis memperluas authorization.

Project: VaxXinE/red-teaming

Version 1.0 | 04 Oktober 2026

Cara Menggunakan Modul Ini

Reconnaissance adalah fase ketika kita membangun gambaran target sebelum melakukan testing yang lebih invasif. Tujuan modul ini bukan mengumpulkan sebanyak mungkin data, tetapi menghasilkan attack-surface inventory yang punya sumber, timestamp, confidence, dan status scope yang jelas.



Gambar 1. Pipeline recon yang menempatkan scope validation sebelum active validation.

Learning Outcomes

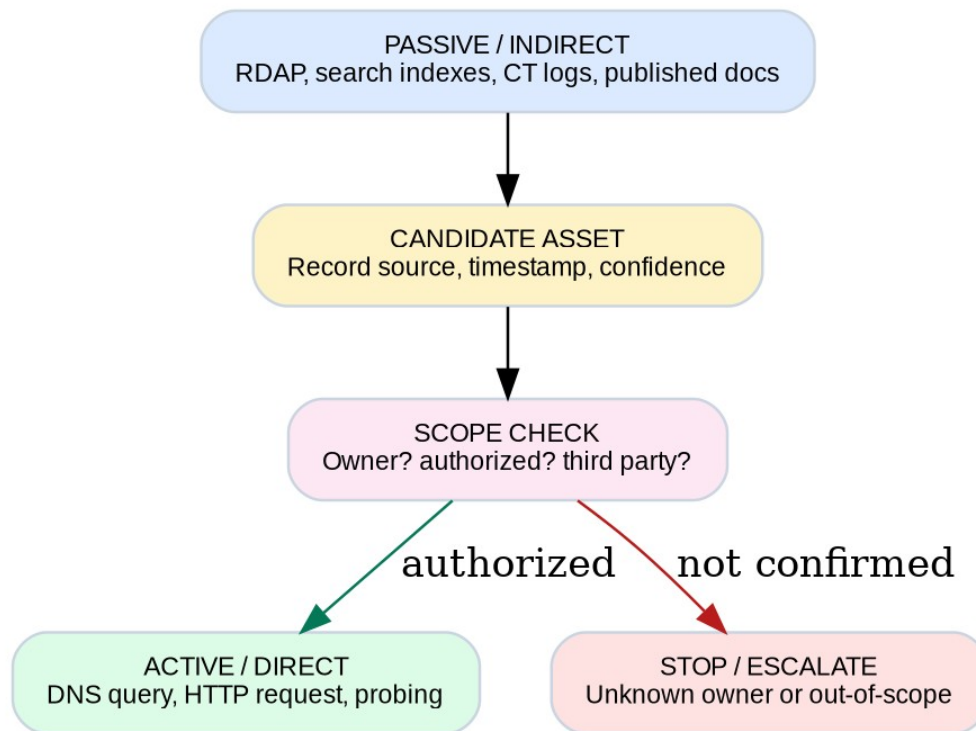
- [] Membedakan passive/indirect discovery dengan active/direct validation.
- [] Mengambil registration data modern melalui RDAP dan memahami posisi WHOIS sebagai legacy fallback.
- [] Membaca record DNS utama sebagai hubungan antar-aset, bukan sekadar output command.
- [] Memahami Certificate Transparency (CT) sebagai sumber nama host yang pernah muncul pada sertifikat publik.
- [] Melakukan search-engine dan document metadata recon secara konservatif.
- [] Mencatat candidate asset dengan provenance, confidence, dan scope status.
- [] Melakukan minimal active fingerprinting hanya pada local/owned lab.
- [] Menghasilkan recon summary yang siap dipakai pada Module 08 Network Enumeration.

Prerequisites

- Module 00-06 selesai atau konsepnya dipahami.
- Nyaman dengan Linux CLI, DNS dasar, HTTP dasar, Python, dan engagement scope.
- Docker tersedia untuk local web fingerprinting lab.

1. Recon Mindset: Temukan, Korelasikan, Validasi

Kesalahan pemula yang paling umum adalah menyamakan discovery dengan permission. Dalam engagement profesional, recon menghasilkan candidate assets. Candidate itu baru boleh masuk active testing setelah ownership dan scope-nya tervalidasi.



Gambar 2. Passive discovery boleh menghasilkan candidate; active validation tetap menunggu scope confirmation.

Think Like an Attacker

Pertanyaan yang lebih berguna daripada "tool apa yang dipakai?" adalah: aset apa yang mungkin belum tercantum, bukti apa yang menghubungkannya ke organisasi, seberapa yakin kita, dan apakah kita boleh menyentuhnya?

Passive, Semi-passive, Active

Kategori	Contoh	Kontak ke target?	Catatan
Passive / indirect	RDAP, CT logs, search engine index	Tidak langsung	Tetap catat ToS/rate limits pihak ketiga.
Low-touch validation	DNS query, satu HTTP HEAD/GET	Ya	Hanya jika scope mengizinkan; gunakan rate rendah.
Active enumeration	Brute-force DNS, crawling agresif, probing service	Ya, signifikan	Masuk Module 08+ dan wajib explicit authorization.

Security Note

"Publicly accessible" bukan sinonim "authorized to test". Bahkan data passive dapat menunjuk ke SaaS, CDN, vendor, acquisition lama, atau shared hosting yang bukan aset organisasi.

2. Data Quality: Provenance, Confidence, Scope Status

Recon yang baik harus bisa diaudit. Jangan simpan hanya hostname. Simpan juga dari mana hostname itu ditemukan, kapan dikumpulkan, seberapa yakin korelasinya, dan status scope-nya.

Field	Contoh	Mengapa penting
asset_type	hostname	Memudahkan normalisasi dan filtering.
value	portal.example.com	Identifier kandidat.
source	CT log / DNS / website	Menjelaskan provenance.
timestamp_utc	2026-10-04T13:00:00Z	Data recon berubah seiring waktu.
confidence	low / medium / high	Membedakan petunjuk dari fakta kuat.
scope_status	candidate / in-scope / out-of-scope	Menjaga authorization boundary.
notes	CNAME ke vendor.example	Konteks untuk analyst berikutnya.

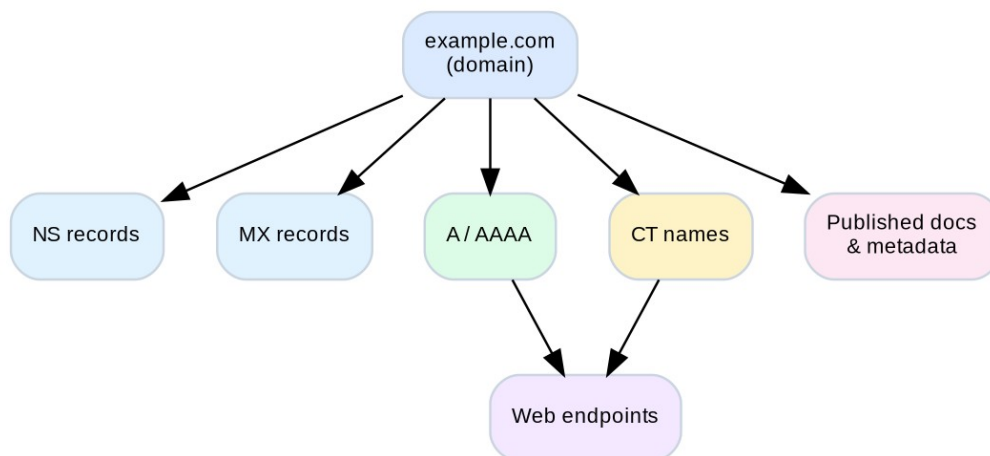
Confidence Bukan Severity

- High confidence: beberapa sumber independen konsisten atau data authoritative.
- Medium confidence: satu sumber yang cukup kuat tetapi belum tervalidasi.
- Low confidence: indikasi lemah, stale, ambiguous, atau berasal dari aggregation service.

Common Mistake

Jangan menaikkan confidence hanya karena tool menampilkan output dengan format meyakinkan. Tool bisa salah, data bisa stale, DNS bisa shared, dan CT bisa menyimpan nama historis.

Asset Graph



Gambar 3. Satu domain dapat mengarah ke beberapa tipe evidence dan hubungan aset.

3. Registration Data: RDAP Menggantikan WHOIS

Untuk gTLD, ICANN menjadikan Registration Data Access Protocol (RDAP) sebagai sumber definitif mulai 28 Januari 2025. RDAP menggunakan model HTTP/JSON yang lebih terstruktur, mendukung internationalization, secure access, service discovery, dan differentiated access. WHOIS tetap berguna sebagai konsep historis/legacy, tetapi modul ini memprioritaskan RDAP.

Concept

RDAP menjawab pertanyaan registration data seperti registrar, status domain, nameserver, dan event timestamps. Data tertentu dapat direduksi/redacted sesuai kebijakan dan privacy requirements.

Tools

Tool	Peran	Omarchy / Arch
rdap_lookup.py	Client training: IANA bootstrap -> authoritative RDAP	Bundled dalam module labs
ICANN Lookup	Browser-based RDAP client	Tidak perlu install
whois	Legacy/fallback client	Package: whois
curl + jq	Inspect JSON/API responses	Biasanya tersedia; jq via repo resmi

Hands-on Lab 1 - Initialize Recon Workspace

```
chmod +x labs/recon-init.sh
./labs/recon-init.sh ~/CyberSec/labs/module07-recon
cd ~/CyberSec/labs/module07-recon
find . -maxdepth 2 -type d -print
```

Expected: folder scope, raw data, normalized data, assets, evidence, dan summary dibuat dengan restrictive umask.

Hands-on Lab 2 - RDAP pada example.com

```
python /path/to/module07/labs/rdap_lookup.py example.com \
--output 01-raw/rdap-example.com.json

jq '{ldhName,status,nameservers,events}' \
01-raw/rdap-example.com.json
```

Observe

Catat registrar/registration events bila tersedia, status domain, nameserver, dan field yang redacted. Jangan menyimpulkan ownership hanya dari satu field.

4. DNS sebagai Peta Hubungan Aset

DNS bukan sekadar "domain ke IP". Record yang berbeda mengungkap role dan dependency: A/AAAA mengarah ke address, MX ke mail infrastructure, NS ke authoritative DNS, CAA ke CA policy, TXT sering membawa verification/SPF metadata, dan SOA memberi zone authority information.

Record	Makna umum	Recon question
A / AAAA	IPv4 / IPv6 address	Address ini dedicated, CDN, atau shared?
NS	Authoritative nameserver	DNS di-host sendiri atau provider?
MX	Mail exchanger	Mail dikelola internal atau SaaS?
TXT	Arbitrary policy/verification text	Ada provider verification atau SPF include?
CAA	CA authorization	CA mana yang boleh menerbitkan certificate?
SOA	Zone authority metadata	Primary zone authority dan serial?
CNAME	Alias ke canonical name	Ada dependency third party?

Install Core Tools di Omarchy

```
omarchy pkg add bind whois jq perl-image-exiftool
```

Package bind menyediakan dig/host/nslookup di Arch. whois dan perl-image-exiftool juga tersedia dari repository resmi Arch.

Hands-on Lab 3 - DNS Baseline

```
chmod +x /path/to/module07/labs/dns-baseline.sh
/path/to/module07/labs/dns-baseline.sh example.com 01-raw/dns-example.com.txt

less 01-raw/dns-example.com.txt
```

Think

Untuk setiap record, tanyakan: apakah ini aset organisasi, dependency pihak ketiga, atau shared infrastructure? Jangan otomatis memasukkan semua IP/provider ke scope.

Hands-on Lab 4 - Log Observation

```
python /path/to/module07/labs/asset-log.py 03-assets/assets.csv \
--type domain --value example.com --source rdap \
--scope candidate --confidence high \
--notes "training example domain"
```

5. Certificate Transparency (CT)

Certificate Transparency adalah framework terbuka untuk monitoring dan auditing certificate. Sertifikat publik dicatat ke append-only logs yang dapat dicari. Dari sisi recon, CT dapat memberikan hostname yang pernah dimasukkan ke certificate Subject Alternative Name (SAN).

Important

CT adalah historical evidence, bukan live-host guarantee. Hostname bisa sudah tidak resolve, sudah pindah provider, merupakan wildcard, atau tidak lagi dimiliki organisasi.

Hands-on Lab 5 - CT JSON + Normalization

Untuk training, gunakan example.com atau domain yang lo miliki. Jangan membuat query loop berkecepatan tinggi ke public CT services.

```
curl --fail --silent --show-error \
  'https://crt.sh?q=%25.example.com&output=json' \
  -o 01-raw/ct-example.com.json

python /path/to/module07/labs/ct-extract.py \
  01-raw/ct-example.com.json --domain example.com \
  | tee 02-normalized/ct-names.txt
```

Kalau service publik sedang rate-limit/down, simpan lab ini untuk nanti. Objective-nya memahami normalization: wildcard dibuang, newline SAN dipisah, lalu hanya suffix domain yang valid yang dipertahankan.

Correlation Rule

Signal	Confidence awal	Next step
CT name saja	Low-Medium	Cari DNS / ownership evidence.
CT + DNS resolve	Medium	Scope validation sebelum HTTP request.
CT + DNS + documented in-scope domain pattern	Medium-High	Konfirmasi engagement owner.
CT points to known third-party SaaS	Low for ownership	Mark third-party / needs validation.

6. Search Engine & Public Web Recon

Search engines sudah melakukan crawling untuk kita. Ini membuat search-index recon berguna untuk melihat konten yang pernah dipublish tanpa langsung melakukan crawling sendiri. OWASP WSTG memasukkan search engine discovery sebagai bagian information gathering.

Hands-on Lab 6 - Safe Search Queries

Gunakan browser. Contoh di bawah sengaja konservatif; untuk engagement nyata, ganti dengan domain yang memang tercakup authorization.

```
site:example.com
site:example.com filetype:pdf
site:example.com filetype:txt
```

- Catat URL, page title, indexed timestamp bila terlihat, dan apakah hasil tersebut current atau stale.
- Jangan mengunduh credential dumps, exposed secrets, private keys, atau data personal hanya karena search engine menampilkannya. Escalate jika menemukannya.
- robots.txt bukan access-control mechanism; jangan menganggap path yang disebut di sana otomatis boleh diuji.

Blue Team Perspective

Public artifacts, forgotten subdomains, old documents, and staging references memperbesar attack surface. Defender perlu punya asset inventory dan content publishing hygiene yang sama kuatnya dengan tester recon.

Public Source vs Target Interaction

Action	Direct target interaction?	Default treatment
Search engine query	Tidak	Passive/indirect
Reading indexed result snippet	Tidak	Passive/indirect
Opening target URL	Ya	Active/low-touch
Automated crawling	Ya, banyak request	Explicit scope + rate limit

7. Document & Metadata OSINT

Dokumen publik bisa membawa metadata seperti author, application name, creation/modification times, camera/GPS tags, template names, dan embedded identifiers. Metadata bisa membantu korelasi, tetapi juga mudah stale atau misleading.

Hands-on Lab 7 - Inspect Metadata Locally

Gunakan file yang lo miliki sendiri. Cara paling gampang: inspect PDF module ini atau sebuah foto dummy lokal. Jangan upload personal photo ke service online hanya untuk lab.

```
exiftool Red-Team-Module-07-Reconnaissance-OSINT-0marchy.pdf

# Untuk output yang lebih ringkas:
exiftool -FileName -FileType -Creator -Producer -CreateDate -ModifyDate \
  Red-Team-Module-07-Reconnaissance-OSINT-0marchy.pdf
```

Security Note

Metadata dapat mengandung PII seperti username lokal, GPS, nama author, atau software version. Simpan evidence hanya sesuai data-handling agreement.

Metadata Reliability

- Metadata dapat diedit atau dihapus.
- Timestamp dapat berasal dari timezone berbeda.
- Creator/Producer menggambarkan toolchain dokumen, bukan selalu user identity.
- Satu nama author bukan bukti bahwa orang tersebut masih bekerja di organisasi.

8. Minimal Technology Fingerprinting - Local Only

Fingerprinting adalah proses mengidentifikasi teknologi dari observable behavior: response headers, TLS certificate, page structure, cookies, error pages, dan protocol characteristics. Karena ini berinteraksi langsung dengan service, kita latihan hanya ke localhost.

Hands-on Lab 8 - Local Nginx Fingerprint

```
chmod +x /path/to/module07/labs/local-web-lab.sh
/path/to/module07/labs/local-web-lab.sh create
/path/to/module07/labs/local-web-lab.sh status
/path/to/module07/labs/local-web-lab.sh headers
```

Perhatikan status code, Server header bila ada, content type, date, dan connection behavior. Setelah selesai:

```
/path/to/module07/labs/local-web-lab.sh cleanup
```

Common Mistake

Header `Server: nginx` adalah clue, bukan proof version. Reverse proxy, CDN, header stripping, dan deliberate deception dapat mengubah fingerprint.

Red Team vs Blue Team Perspective

Red Team question	Blue Team control
Apa teknologi yang bocor dari header?	Minimize unnecessary banners; patch regardless of banner.
Apakah cookie names/framework hints membantu?	Use secure cookie attributes and avoid relying on obscurity.
Apakah staging/dev terlihat publik?	External asset monitoring + deployment governance.
Apakah certificate SAN mengungkap naming convention?	Certificate issuance review + asset inventory.

9. Attack Surface Mapping

Final output recon bukan folder berisi command output. Output yang berguna adalah inventory yang menghubungkan assets, sources, scope status, dan unresolved questions.

Recommended Asset States

State	Meaning	Allowed next action
candidate	Baru ditemukan	Correlate; jangan probe.
needs-validation	Ada indikasi ownership tetapi ambiguous	Tanya engagement owner.
in-scope	Confirmed by scope/change control	Boleh active validation sesuai RoE.
out-of-scope	Explicit exclusion/third-party	Stop; document only.

Hands-on Lab 9 - Build Asset Inventory

```
python /path/to/module07/labs/asset-log.py 03-assets/assets.csv \
--type hostname --value www.example.com --source dns \
--scope candidate --confidence medium

python /path/to/module07/labs/asset-log.py 03-assets/assets.csv \
--type url --value http://127.0.0.1:8087/ --source local-lab \
--scope in-scope --confidence high

column -s, -t < 03-assets/assets.csv | less -S
```

Think

Kalau CT menemukan `old-vpn.example.com` tetapi DNS tidak resolve, jangan buang. Tandai historical candidate. Historical names bisa menjelaskan naming convention, migration, atau stale certificate hygiene.

Hands-on Lab 10 - Generate Recon Summary

```
python /path/to/module07/labs/recon-summary.py \
03-assets/assets.csv --output 05-summary/recon-summary.md

cat 05-summary/recon-summary.md
```

10. Tool Spotlight: Amass

OWASP Amass adalah framework attack-surface mapping dan external asset discovery yang menggabungkan open-source intelligence dan reconnaissance techniques. Tool ini powerful, tetapi otomatisasi dapat memicu banyak third-party requests dan mode tertentu bisa melakukan active reconnaissance.

Use It Later, Use It Deliberately

Di module ini Amass bersifat optional. Jangan menjalankan active enumeration pada organisasi random. Gunakan domain milik sendiri atau scope training resmi, dan baca ``amass -h`` / ``amass enum -h`` karena CLI dan data model proyek berkembang dari versi ke versi.

Safer Installation Choice di Omarchy

Untuk security tooling besar yang berubah cepat, prefer official release atau official Docker image daripada random AUR package. Review provenance, version, checksum/signature bila tersedia, dan jalankan container dengan volume/output yang eksplisit.

```
# Pelajari current CLI dari image resmi project
sudo docker run --rm caffix/amass:latest -h

# Lalu cek help subcommand sebelum menjalankan enumeration
sudo docker run --rm caffix/amass:latest enum -h
```

Jika lo punya domain lab sendiri, baru ikuti official Amass documentation untuk passive enumeration. Kalau tidak punya, skip - seluruh learning outcome module ini tetap tercapai dengan RDAP, DNS, CT, search engine, dan local fingerprinting.

Why Not Install Every OSINT Tool?

- Tool sprawl menambah supply-chain risk dan maintenance burden.
- API-based OSINT tools sering membutuhkan credentials; secret handling perlu disiplin.
- Automation dapat menciptakan noisy/high-volume traffic tanpa disadari.
- Fundamental provenance dan scope reasoning lebih penting daripada jumlah tool.

11. Mini Project - Recon Notebook yang Bisa Diaudit

Mini project ini menggabungkan seluruh modul. Gunakan `example.com` untuk public-data exercises dan localhost untuk direct interaction. Target akhir: folder recon yang orang lain bisa review tanpa menebak bagaimana data ditemukan.

1. Buat workspace dengan recon-init.sh.
2. Ambil RDAP example.com dan simpan raw JSON.
3. Ambil DNS baseline example.com.
4. Jika CT service tersedia, download satu JSON response dan normalize names.
5. Log minimal 5 observations ke assets.csv dengan source/confidence/scope status.
6. Jalankan local Nginx lab dan simpan response headers sebagai evidence.
7. Inspect metadata PDF module dengan ExifTool.
8. Generate recon-summary.md.
9. Review semua candidate dan tulis apa yang masih membutuhkan owner validation.
10. Cleanup local container.

Definition of Done

- [] Tidak ada active probing ke non-owned public systems.
- [] Setiap observation punya source/provenance.
- [] Candidate asset tidak otomatis diberi status in-scope.
- [] Raw evidence disimpan terpisah dari normalized inventory.
- [] Timestamps menggunakan UTC bila memungkinkan.
- [] Local web lab sudah di-cleanup.
- [] Summary menjelaskan unresolved scope questions.

Professional Habit

Recon notebook yang rapi mengurangi duplicate work, salah scope, dan false assumptions. Ini juga membuat handoff ke tester lain jauh lebih aman.

12. Practical Challenge - 45 Menit

Skenario: lo menerima engagement training dengan hanya satu seed domain `example.com`, tetapi active testing public Internet dilarang. Direct interaction hanya boleh ke localhost. Buat attack-surface draft yang bisa dipertanggungjawabkan.

Objectives

- [] Kumpulkan RDAP dan DNS evidence.
- [] Catat minimal satu dependency clue dari DNS (mis. nameserver atau mail provider) tanpa mengklaim itu in-scope.
- [] Kumpulkan/normalize CT data jika tersedia.
- [] Buat minimal 5 baris assets.csv.
- [] Jalankan local web fingerprinting dan simpan headers.
- [] Generate recon-summary.md.
- [] Tulis 3 pertanyaan yang harus dijawab engagement owner sebelum active enumeration.

Scoring Rubric

Area	Points	Pass condition
Scope discipline	30	Tidak ada unauthorized active interaction.
Evidence/provenance	20	Raw evidence + source jelas.
Normalization	20	Asset type/status/confidence konsisten.
Technical understanding	20	Bisa jelaskan makna RDAP/DNS/CT clues.
Cleanup/reporting	10	Local lab clean + summary terbaca.

Target pass: 80/100. Kalau score rendah karena tool gagal/rate-limit tetapi reasoning dan evidence discipline benar, ulangi tool step nanti - jangan mengganti target dengan organisasi random.

13. Knowledge Check

1. Kenapa discovered asset tidak otomatis menjadi in-scope asset?
2. Apa perbedaan passive discovery dan active validation?
3. Mengapa RDAP diprioritaskan dibanding WHOIS untuk gTLD modern?
4. Apa fungsi IANA bootstrap pada RDAP?
5. Apa perbedaan A, AAAA, MX, NS, TXT, CAA, dan SOA?
6. Mengapa shared IP tidak cukup membuktikan ownership?
7. Apa yang bisa dipelajari dari Certificate Transparency?
8. Mengapa CT hostname bisa stale?
9. Kenapa source/provenance harus dicatat?
10. Apa bedanya confidence dengan scope status?
11. Kenapa search-engine recon dianggap indirect?
12. Kenapa membuka URL target berbeda dari membaca search result snippet?
13. Apa risiko metadata pada dokumen publik?
14. Mengapa Server header bukan bukti kuat version?
15. Kapan candidate asset harus diberi needs-validation?
16. Apa manfaat menyimpan raw evidence terpisah dari normalized asset list?
17. Mengapa UTC berguna untuk recon notes?
18. Kenapa automated OSINT tools tetap perlu rate/authorization review?
19. Apa alasan menggunakan localhost untuk fingerprinting lab?
20. Apa output utama reconnaissance yang profesional?

Exit Criteria

Lo siap lanjut ke Module 08 kalau lo bisa mengambil satu seed domain, membuat evidence-backed asset inventory, membedakan candidate vs in-scope, menjelaskan RDAP/DNS/CT relationships, dan melakukan minimal validation tanpa keluar dari scope.

14. Cheat Sheet

Tujuan	Command / Tool
Install core tools	omarchy pkg add bind whois jq perl-image-exiftool
RDAP	python rdap_lookup.py example.com --output rdap.json
DNS A	dig +noall +answer example.com A
DNS MX	dig +noall +answer example.com MX
DNS NS	dig +noall +answer example.com NS
DNS CAA	dig +noall +answer example.com CAA
CT fetch	curl ... crt.sh ... -o ct.json
CT normalize	python ct-extract.py ct.json --domain example.com
Metadata	exiftool file.pdf
Local headers	curl -sS -D - -o /dev/null http://127.0.0.1:8087/
Log asset	python asset-log.py assets.csv --type ... --value ... --source ...
Summary	python recon-summary.py assets.csv --output recon-summary.md

Recon Decision Loop

```

SEED -> DISCOVER -> RECORD SOURCE -> CORRELATE
      -> OWNERSHIP/SCOPE CHECK
          -> if UNKNOWN: STOP + ASK
          -> if IN-SCOPE: MINIMAL VALIDATION
      -> NORMALIZE -> SUMMARY -> HANDOFF
  
```

Golden Rule

The objective is not maximum collection. The objective is enough trustworthy context to make the next authorized technical decision safely.

15. References

ICANN - Launching RDAP; Sunsetting WHOIS - RDAP definitive for gTLD registration data from 28 Jan 2025.

<https://www.icann.org/en/announcements/details/icann-update-launching-rdap-sunsetting-whois-27-01-2025-en>

ICANN - Information for RDAP Users - RDAP clients, requirements, and usage context.

<https://www.icann.org/en/contracted-parties/registry-operators/registration-data-access-protocol/information-for-rdap-users-31-08-2018-en>

Google PKI - What is Certificate Transparency? - CT as public, verifiable, append-only certificate logs.

<https://developers.google.com/public-key-infrastructure/faq/what-is-certificate-transparency>

OWASP WSTG v4.2 - Search Engine Discovery Reconnaissance - Search-index reconnaissance concepts.

https://wstg.owasp.org/v4.2/4-Web_Application_Security_Testing/01-Information_Gathering/01-Conduct_Search_Engine_Discovery_Reconnaissance_for_Information_Leakage/

OWASP WSTG - Information Gathering Overview - Passive + active discovery and scope reminder.

https://wstg.owasp.org/latest/4-Web_Application_Security_Testing/01-Information_Gathering/00-Information_Gathering_Overview/

OWASP Amass Project - Attack-surface mapping and external asset discovery framework.

<https://owasp.org/projects/amass>

NIST SP 800-115 - Testing and assessment guidance; discovery techniques and engagement discipline.

<https://csrc.nist.gov/pubs/sp/800/115/final>

Arch Linux - bind package - Provides DNS tooling such as dig.

https://archlinux.org/packages/extra/x86_64/bind/

Arch Linux - whois package - Legacy WHOIS client package.

<https://security.archlinux.org/package/whois>

Arch Linux - perl-image-exiftool - Metadata inspection tool.

<https://archlinux.org/packages/extra/any/perl-image-exiftool/>

Catatan: service publik, CLI, dan toolchain dapat berubah. Selalu cek official documentation/help output sebelum automation. Untuk lab publik gunakan request minimal dan patuhi rate limits/terms provider.